BÁO CÁO BẢO MẬT (ATTT)

Sản phẩm: ZeroCheck AI — Chiến binh y tế số · https://cbyts.vnpt.vn

Phạm vi: biện pháp ATTT đã triển khai (xác thực, phân quyền, bảo vệ dữ liệu), kết quả tự rà soát, các phát hiện & xử lý trong quá trình phát triển, khuyến nghị.

---

1. Triết lý: "Không giữ thứ để mất"

Hệ thống xử lý dữ liệu y tế — nhạy cảm bậc nhất — nên nguyên tắc số 1 là **không lưu trữ hồ sơ bệnh án**:

Biện pháp	Chi tiết
Hồ sơ XML 130 kiểm xong là bỏ	Xử lý trong bộ nhớ theo từng request — **không ghi đĩa, không lưu CSDL**
CSDL chỉ chứa dữ liệu không định danh	Danh mục (ICD, thuốc, DVKT), văn bản quy phạm, cấu hình
Nhật ký & lịch sử hoạt động	Chỉ ghi mã liên kết **MA_LK**; phần lưu kết quả kiểm tra **cố ý loại bỏ họ tên/mã thẻ** ngay từ tầng ghi
AI chạy tại chỗ được	Ollama trong hạ tầng đơn vị — dữ liệu không rời khỏi cơ sở; nếu dùng AI đám mây, chỉ gửi mô tả lỗi, **không gửi định danh bệnh nhân**

→ Kịch bản xấu nhất (CSDL bị xâm nhập) không làm lộ bệnh án, vì hệ thống không có bệnh án.

2. Xác thực & phân quyền

Hạng mục	Triển khai
Đăng nhập	JWT access token + **refresh token lưu dạng hash** trong CSDL
Mật khẩu	ASP.NET Identity (băm chuẩn); quên mật khẩu qua email với liên kết đặt lại có hạn
Phân quyền	RBAC chi tiết dạng `Resource.Action` (14+ quyền, seed tự động); **kiểm tra tại từng endpoint** bằng `[RequirePermission]`; frontend ẩn chức năng không có quyền (chỉ là tiện dụng — quyền thật chặn ở API)
Vai trò mặc định	SystemAdmin / Manager / Viewer; tạo thêm vai trò và tick quyền theo nhóm trên web admin
Kiểm toán	**Audit log** ai-sửa-gì-lúc-nào cho thay đổi cấu hình/quyền; xóa dữ liệu là **xóa mềm** (giữ vết, khôi phục được)

3. Chống tấn công lớp ứng dụng

Nguy cơ	Biện pháp	Vị trí
SQL Injection	EF Core **tham số hóa 100%**, không ghép chuỗi SQL; tìm kiếm toàn văn qua `EF.Functions`	toàn bộ tầng dữ liệu
XXE (XML External Entity)	Đọc XML bằng XDocument — **không DTD, không thực thể ngoài**	parser XML 130
Upload phá hoại	Whitelist content-type; giới hạn kích thước: XML 50MB, văn bản 20MB, lô batch 1GB	các endpoint upload
Dò mật khẩu (brute-force)	Rate limit **đăng nhập 5 lần/phút/IP**; quên mật khẩu 3/phút (chống spam email)	middleware RateLimiter
Spam / lạm dụng chi phí AI	Hỏi đáp AI 10/phút/IP; nạp đặc tả 5/phút; **chung toàn API 100/phút/IP** (cộng dồn); vượt → HTTP 429 + `Retry-After`, thông báo tiếng Việt; phân vùng theo **IP thật** (`X-Forwarded-For` sau ingress); **ngưỡng chỉnh runtime** trên web admin	middleware + web admin
Lộ thông tin qua lỗi	Middleware lỗi toàn cục: client chỉ nhận mã lỗi chuẩn + `traceId`, **không lộ stack trace**	GlobalExceptionMiddleware
Lộ bí mật cấu hình	API key qua user-secrets (dev) / biến môi trường (production); **repo không chứa key**	cấu hình
Vận chuyển	HTTPS/TLS tại ingress (cbyts.vnpt.vn)	hạ tầng K8s

4. Kết quả tự rà soát bảo mật

Rà soát chéo bằng AI agent + kiểm thử tay trong quá trình phát triển:

Hạng mục rà soát	Kết quả	Ghi chú
Tìm chuỗi SQL nối tay trong toàn bộ mã	✅ Không có	100% qua EF Core
Tìm secret/key trong mã nguồn & lịch sử cấu hình	✅ Sạch ở mã hiện hành	xem mục 5 — có phát hiện & xử lý
Kiểm tra [Authorize]/[RequirePermission] các endpoint quản trị	✅ Đầy đủ ở nhóm Auth/cấu hình/thống kê	các endpoint nghiệp vụ mở cho extension theo thiết kế
Log có chứa dữ liệu bệnh nhân?	✅ Không — chỉ MA_LK và số lượng vấn đề	quy ước ghi log
Thử vượt rate limit (login, ask)	✅ Trả 429 + Retry-After đúng thiết kế	kiểm thử tay
Refresh token trong DB	✅ Dạng hash, có hạn, thu hồi được	
Payload lịch sử hoạt động	✅ Đã kiểm không chứa họ tên/mã thẻ	thiết kế cố ý ở tầng ghi

5. Phát hiện & xử lý trong quá trình phát triển (minh bạch)

Phát hiện	Xử lý
Một API key LLM từng bị đưa nhầm vào nơi không an toàn trong giai đoạn đầu	Thu hồi/thay khóa; chuyển hẳn sang user-secrets/biến môi trường; đưa thành quy ước trong CLAUDE.md
Mật khẩu quản trị demo được trao đổi qua kênh chat khi phối hợp	Đổi mật khẩu sau cuộc thi (đã ghi vào việc-phải-làm)
CORS bản demo cho phép origin rộng để tiện chấm thi	Kế hoạch siết về đúng ID extension khi sản phẩm hóa
Extension chặn quảng cáo của trình duyệt chặn nhầm endpoint thống kê (`/stats/`)	Đổi route tránh từ khóa nằm trong blocklist — bài học đặt tên endpoint

6. Khuyến nghị khi triển khai chính thức

1. Siết CORS về `chrome-extension://<id>`; bật HSTS.
2. Tích hợp SSO/danh bạ tập trung của đơn vị (hệ thống đã tách tầng xác thực nên thay được).
3. Bổ sung SAST + quét phụ thuộc (dependency scan) vào pipeline CI/CD.
4. Thực hiện pentest độc lập trước khi dùng diện rộng.
5. Chính sách vòng đời dữ liệu cho bảng lịch sử hoạt động (tự xóa sau N tháng).